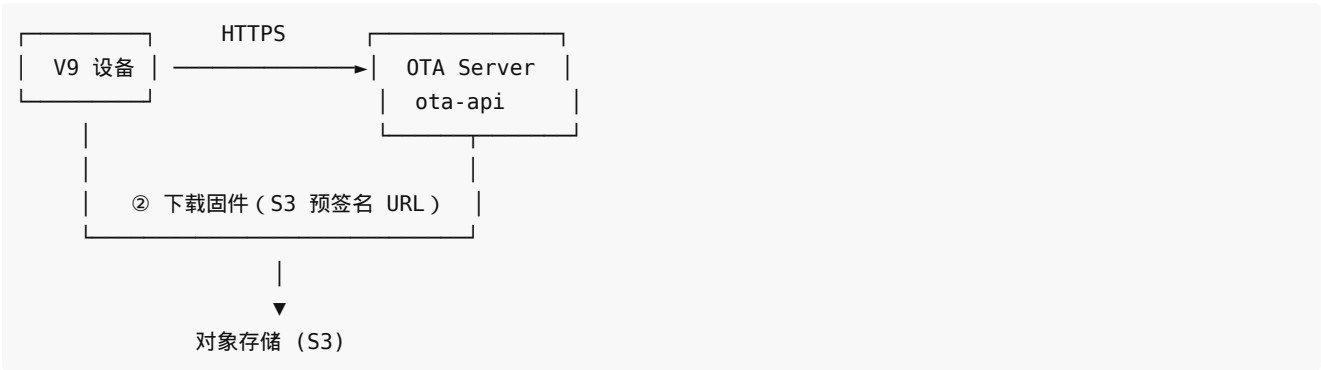


V9 设备 OTA 对接手册

面向 V9 设备固件开发。设备 **直接访问 OTA Server**，不经过业务主系统。

1. 对接概览



设备侧只需实现：

1. 周期性调用 `check-update` 查询是否有升级
2. 有升级时下载固件并刷写
3. 升级过程中调用 `report-status` 上报进度与结果

前置条件（由运营 / OTA 平台完成，设备无需参与）：

- 设备已在 OTA 平台注册（`device_id` = 设备 SN）
- 存在针对该设备的 **Running** 发布任务
- 固件包已上传至对象存储

2. 环境与地址

项	说明	占位符
OTA API 基址	所有设备 API 的前缀	<OTA_API_PUBLIC_URL>
示例	生产	https://ota-api.example.com
示例	联调	http://192.168.x.x:8080

完整 URL：

- 检查更新：POST <OTA_API_PUBLIC_URL>/device/v1/check-update
- 上报状态：POST <OTA_API_PUBLIC_URL>/device/v1/report-status

demogo 示例： https://demogo.work/ota/device/v1/check-update （经 Caddy 子路径；签名 path 仍为 /device/v1/check-update ）。

联调时可使用管理台内置模拟器： https://demogo.work/ota/#/simulator （填写 `device_id` + `device_secret`，自动 HMAC 签名）。

3. 鉴权（per-device HMAC）

每台 V9 在产线烧录唯一 `device_secret`，OTA 平台注册表存同值（见部署手册 provision 接口）。

3.1 服务端配置（运维侧）

```
DEVICE_API_AUTH_ENABLED=true
DEVICE_AUTH_TIMESTAMP_TOLERANCE_SEC=300
```

与 OAuth/SSO 无关：设备 API 不使用管理台 OIDC token；device_secret 由产线烧录 + 平台 provision。
仅本地开发可设 DEVICE_API_AUTH_ENABLED=false 跳过签名校验；**demogo / 生产须为 true**。

3.2 请求头

```
Authorization: Device device_id=<SN>,timestamp=<unix>,signature=<base64url_hmac>
Content-Type: application/json
```

3.3 签名算法

- 计算请求体 SHA256（十六进制小写）：`body_hash = sha256_hex(raw_json_body)`
- 拼接 payload（UTF-8，\n 分隔）：

```
<timestamp>
<METHOD>
<path>
<body_hash>
```

示例 path：/device/v1/check-update（与真实请求路径一致，含前缀）。

- 计算签名：`signature = Base64URL( HMAC-SHA256(device_secret, payload) )`
- timestamp 为 Unix 秒，与服务端时差不超过 DEVICE_AUTH_TIMESTAMP_TOLERANCE_SEC（默认 300s）。

3.4 伪代码

```
body_hash = sha256_hex(json_body);
payload = sprintf("%d\n%s\n%s\n%s", timestamp, "POST", path, body_hash);
signature = base64url(hmac_sha256(device_secret, payload));
header = sprintf("Device device_id=%s,timestamp=%d,signature=%s", sn, timestamp, signature);
```

3.5 错误响应

HTTP	code	含义
401	1001	签名错误、时间戳过期、或 header/body 的 device_id 不一致
403	2003	设备未注册
403	2004	设备被禁用
403	2007	未 provision device_secret（产线/运维需写入）

4. 请求字段

JSON 字段	必填	含义
device_id	是	设备 SN
current_version	建议	当前固件版本，如 v2.3.0

无需 在请求中传 group / product_model / hardware_version ——服务端按 device_id 查注册表。

版本号格式：建议 v主.次.修订。服务端以平台 reported_version / catalog 为主，current_version 仅在平台记录滞后时作只读补充（只允许往高取，不会被低版本拉低判断）。

固件需固化配置：

配置项	说明
ota_api_base_url	<OTA_API_PUBLIC_URL>
device_id	SN
device_secret	产线烧录，每台唯一

5. 接口一：检查更新

5.1 请求

```
POST /device/v1/check-update
Authorization: Device device_id=AMS000001,timestamp=1717930000,signature=...
Content-Type: application/json

{
  "device_id": "AMS000001",
  "current_version": "v2.3.0"
}
```

必填：device_id。

5.2 有升级 (HTTP 200, code=0)

```
{
  "code": 0,
  "message": "ok",
  "data": {
    "has_update": true,
    "task_id": "task-uuid-xxx",
    "package_id": "pkg-uuid-xxx",
    "target_version": "v2.4.0",
    "file_hash": "sha256:abcdef...",
    "signature": "包签名 (若有)",
    "download_url": "https://s3.example.com/ota-packages/...?X-Amz-...",
    "current_version": "v2.3.0",
    "upgrade_mode": "full",
    "retry_policy": "full-retry",
    "target_group": "org-1001",
    "target_model": "V9",
    "target_hardware": "1.0",
    "failure_threshold": 0.05,
    "retry_after_sec": 86400
  }
}
```

设备必须保存：

字段	用途
task_id	后续所有 report-status 必带
target_version	上报 Success / Failed 时使用
download_url	HTTP GET 下载固件
file_hash	下载完成后校验（建议 SHA256）

下载 URL 为 **短时有效的预签名链接**（默认约 10 分钟），请在拿到后尽快下载；过期则重新 `check-update` 获取新 URL。

5.3 无升级 (HTTP 200, code=2001)

```
{
  "code": 2001,
  "message": "No available upgrade",
  "data": {
    "has_update": false,
    "reason": "already_latest",
    "retry_after_sec": 86400,
    "current_version": "v2.4.0"
  }
}
```

常见 `reason`：

reason	含义	建议轮询间隔
already_latest	已是最新或高于目标版本	按 <code>retry_after_sec</code> （通常 24h）
no_running_task	无进行中的发布任务	按 <code>retry_after_sec</code>
not_in_canary	任务存在但未命中灰度	按 <code>retry_after_sec</code>
version_not_eligible	当前版本低于包要求的最低可升版本	按 <code>retry_after_sec</code>

轮询策略：无升级时 sleep `retry_after_sec` 再请求，避免频繁打 API。

5.4 错误响应

HTTP	code	message / reason	设备处理
400	1002	缺必填字段	修代码
401	1001	unauthorized	检查签名与时间戳
403	2003	not_in_catalog	设备未在平台注册，联系运营
403	2004	device_blocked	设备被禁用，联系运营
403	2007	device_secret_not_provisioned	联系运维 provision secret
500	5000	服务端错误	退避重试

6. 接口二：上报升级状态

6.1 请求

```
POST /device/v1/report-status
Authorization: Device device_id=AMS000001,timestamp=1717930000,signature=...
Content-Type: application/json
X-Idempotency-Key: <可选>
```

```
{
  "device_id": "AMS000001",
  "task_id": "task-uuid-xxx",
  "status": "downloading",
  "source_version": "v2.3.0",
  "target_version": "v2.4.0",
  "error_code": "",
  "error_message": ""
}
```

必填： device_id 、 task_id 、 status 。

建议携带： source_version （升级前版本）、 target_version （目标版本，来自 check-update）。

失败时： status 设为 failed ，并填 error_code / error_message 。

6.2 成功响应（HTTP 200, code=0）

```
{
  "code": 0,
  "message": "Status received",
  "data": {
    "idempotency_key": "...",
    "status": "Downloading",
    "source_version": "v2.3.0",
    "target_version": "v2.4.0",
    "error_code": ""
  }
}
```

6.3 状态枚举与推荐流程

服务端会将状态名规范化为首字母大写。设备可发送 **小写** 别名。

推荐上报顺序（全量升级）：

pending → downloading → downloaded → verifying → upgrading → success

设备发送 status	规范化后	说明
pending	Pending	已决策升级，准备下载
downloading	Downloading	正在下载
downloaded / download_success	Downloaded	下载完成

verifying	Verifying	校验 hash / 签名
upgrading	Upgrading	正在刷写
success / upgrade_success	Success	升级成功（终态）
failed / error	Failed	升级失败

失败与回滚（可选）：

status	说明
failed	任意阶段可上报；之后可 rollbacking → rolledback

状态机规则（设备需遵守）：

- 允许 相同状态重复上报（幂等）
- 不允许从后阶段倒退回前阶段（如 Upgrading → Downloading），否则 HTTP 409
- Success / RolledBack 为 终态，不可再变更

6.4 错误响应

HTTP	code	含义
400	1002	缺字段或非法 status
401	1001	Token 错误
409	2005	非法状态迁移（见上）

7. 完整升级流程（参考实现）



report-status: upgrading → 刷写固件 → 重启

report-status: success (带 target_version)

最小实现（资源极紧张时可简化）：

若无法逐步上报，至少保证：

1. 开始升级前：pending 或 downloading
2. 结束：success 或 failed（必须带 task_id、target_version）

但强烈建议上报 downloading / downloaded，便于平台统计与故障排查。

8. 固件下载

- 方法：GET，使用 check-update 返回的 download_url
- 无需再带 Bearer Token（URL 已预签名）
- 下载完成后用 file_hash 校验；格式通常为 sha256:<hex>
- URL 过期：重新调用 check-update（同一 task_id 可能仍有效）

默认方案为 S3 预签名 URL 直连对象存储。若运维启用了 DEVICE_DOWNLOAD_HMAC_ENABLED，则 download_url 指向 OTA API 代理地址，设备仍只需 GET 该 URL，无需额外签名逻辑。

9. 幂等与重试

9.1 report-status 幂等

- 请求头 X-Idempotency-Key 可选；不传时服务端按 device_id:task_id:status 自动生成
- 相同 Key 重复请求返回相同结果，不会重复写库
- 网络超时后可安全重试同一 status 上报

9.2 check-update 重试

- 网络错误：指数退避重试
- 收到 2001：按 retry_after_sec 等待，勿高频轮询

10. 联调与验收

10.1 冒烟（需先 provision secret）

```
# 运维：为 SN 写入 secret（管理端 JWT）
curl -X PUT -H "Authorization: Bearer $ADMIN_JWT" -H "Content-Type: application/json" \
  -d '{"device_secret": "your-32byte-secret"}' \
  https://<OTA_API_PUBLIC_URL>/api/v1/devices/AMS000001/device-secret
```

设备侧按 §3.3 构造 Authorization: Device ... 后调用接口。

10.2 验收清单

- ☐ per-device HMAC 签名正确
- ☐ 错误签名 / 过期 timestamp 返回 401
- ☐ 未 provision secret 返回 2007
- ☐ 未注册 SN 返回 403 / not_in_catalog

- ☐ 有任务时能拿到 `download_url` 且 URL 为 公网 HTTPS
- ☐ 下载文件 hash 与 `file_hash` 一致
- ☐ 完整流程上报至 `success` 后，再次 `check-update` 为 `already_latest`
- ☐ 失败场景上报 `failed` + `error_code`
- ☐ 断网重试 `report-status` 不产生 409（同 `status` 重试）

11. 错误码速查

code	HTTP	场景
0	200	成功
1001	401	鉴权失败
1002	400	请求参数错误
1003	403	下载签名无效（HMAC 模式）
2001	200	无可升级
2002	404	包不存在
2003	403	设备不在目录
2004	403	设备被禁用
2005	409	状态迁移非法
2007	403	<code>device_secret</code> 未 provision
5000	500	服务端内部错误

12. 联系方式与配置项汇总

设备固件需固化配置（出厂或首次配网写入）：

配置项	说明
<code>ota_api_base_url</code>	<OTA_API_PUBLIC_URL>
<code>device_id</code>	SN
<code>device_secret</code>	产线烧录，每台唯一

分组 / 型号 / 硬件版本由 OTA 注册表维护，无需写入固件。

13. 相关文档

- 部署与环境变量：`doc/deploy-manual.md`
- 仓库 README 与模拟器：`cmd/device-simulator/README.md`